GRC102 Security Governance Simulation Assessment Brief

Practical Lab 8 Monitoring Auditing Controls and Executive Reporting

Course	GRC102 Information Security Governance
Assessment	Individual practical laboratory 100 marks
Submission	GitHub repository and associated evidence
Name & Surname	Nolusindiso Baby-Joyce Sonjani
Registration Number	C112617560

Part 1: Environment Setup, Scanning, and Governance Baseline (30 Marks)

This phase establishes the simulated infrastructure, produces baseline vulnerability scans, and initializes governance tracking.

- **Architecture & Containerization**:
  - Deploy a multi-tier environment using docker-compose.yml comprising:
    - **Edge / Web tier**: An Apache/Nginx reverse proxy or an intentionally vulnerable application server (such as an unpatched Apache Struts demo instance simulating the Equifax vector).
    - **Application / API tier**: Internal application runtime with simulated access control flaws.
    - **Data tier**: A database engine (PostgreSQL/MySQL) storing mock sensitive records (e.g., mock PII).
  - *Documentation requirement*: Architectural diagram, compose configuration snippets, port bindings, and environment variables.

Vulnerability Scanning:

- Execute an automated vulnerability scanner against the environment (e.g., OpenVAS, Trivy, Grype, or OWASP ZAP).
- Export the raw findings into standardized formats (JSON/PDF).
- *Required Evidence*: Terminal screenshots of the scanner execution, target host logs, and the complete scan report highlighting Critical and High CVEs (e.g., CVE-2017-5638 if Struts-based).

Governance Tracker Initialization:

- Initialize a central risk register or governance tracker (e.g., DefectDojo, OpenSearch dashboard, or a structured risk tracking spreadsheet).
- Import discovered CVEs and assign Risk Owner, CVSS v3 score, Remediation SLA (e.g., Critical = 48h, High = 14d), and ISO/IEC 27001 / NIST CSF control mappings.
- *Required Evidence*: Screenshots of the initialized dashboard showing open items, initial risk score, and SLA timers.

Part 2: Security & Governance Failure Analysis vs. Equifax Case Study (25 Marks)

This phase documents how misconfigurations allowed system compromise during the authorized simulation and analyzes systemic governance breakdowns alongside the 2017 Equifax breach.

- **Simulation Observations & Root Cause Analysis**:
  - **Patch Ingestion Failure**: The vulnerable component remained unpatched despite known public advisories.
  - **Network Visibility Deficit**: Lack of internal ingress/egress decryption or inspection prevented detection of anomalous traffic.
  - **Network Flatness**: Once the web tier was breached, unrestricted internal network access allowed lateral traversal to the database tier.
  - **Lack of Least Privilege**: The application executed with broad administrative privileges and had direct, unsegmented read access to database tables.

Comparative Matrix: Simulation vs. Equifax (2017):

Analysis Dimension	Simulated Environment Failure	Equifax Breach (2017) Parallel	Governance / Systemic Breakdown
Vulnerability & Patching	Known CVE unpatched; scanner identified missing software updates.	Apache Struts vulnerability (CVE-2017-5638) went unpatched on dispute portal for months despite US-CERT alert.	Defective asset inventory; patch notification sent to internal listserv failed to reach responsible engineers.
Network Segmentation	Single bridge network allowed direct access from public web container to database.	Internal network lacked micro-segmentation; attackers pivoted across legacy core environments.	Absence of Zero Trust network architecture; weak boundary protection between tiers.
Credential & Key Management	Plaintext database credentials in config files; unencrypted internal transport.	Internal database credentials found stored in unencrypted files on compromised servers.	Inadequate secrets lifecycle management and policy enforcement.
Monitoring & Detection	Logs unmonitored; no intrusion detection or signature monitoring active.	Attackers operated undetected for 76 days due to an expired SSL/TLS certificate on an inspection device.	Inadequate operational certificate management and continuous monitoring oversight

Required Evidence: Complete Failure Analysis Report detailing vectors, systemic failures, and specific remediation recommendations.

Part 3: Defensive Governance Controls Implementation & Validation (25 Marks)

This phase verifies the implementation of preventive and detective controls across the architecture.

- **1. Patch Management & Baseline Hardening**:
  - Update baseline container images to patched releases.
  - Integrate image scanning into deployment scripts (e.g., Trivy breaking the build if Critical CVEs exist).
  - Run non-root users (USER appuser) within all Dockerfiles.
- **2. Network Micro-Segmentation**:
  - Split the Docker network into discrete bridge networks: frontend_net (Proxy \(\leftrightarrow \) Web) and backend_net (Web \(\leftrightarrow \) DB).
  - Ensure the DB container has no route to frontend_net or public ingress/egress.
- **3. Database Security & Data Protection**:
  - Enforce mandatory TLS encryption for internal database connections.

- Implement database access control ensuring the application user possesses restricted DML-only permissions on necessary tables, prohibiting schema modification or cross-database reads.
- Enable native database audit logging (pg_audit or MySQL enterprise audit/general log).

- **4. Monitoring, Detection & Oversight**:
- Configure centralized logging (e.g., Filebeat/Fluentbit forwarding to an ELK/Grafana stack).
- Deploy detection rules (such as ModSecurity WAF rules or Suricata/Snort signatures) to catch common web injection attempts.
- *Required Evidence*: Post-hardening scan report showing reduction of critical findings to zero, network isolation ping/curl tests demonstrating failed lateral connections, and audit log extracts.

Part 4: Governance Metrics, Executive Dashboard, and Board Reporting (20 Marks)

This phase translates technical remediation into measurable metrics and executive oversight mechanisms.

- **Governance Metrics Framework**:
- **Mean Time to Remediate (MTTR)**: Tracking days from public CVE release to patch deployment against policy thresholds (Critical < 48h).
- **Asset Coverage Rate**: Percentage of active containers/hosts integrated into continuous scanning.
- **Control Compliance Percentage**: Ratio of systems adhering strictly to the hardening baseline (e.g., CIS Benchmarks).
- **Patch SLA Adherence**: Percentage of known vulnerabilities remediated within defined policy timelines.
- **Executive Dashboard Design**:
- High-level visualization summarizing:
  - Fleet vulnerability health (Burndown of Critical/High/Medium issues).
  - Current open risk posture and aging metrics.
  - SLA breach alerts.
- *Deliverable*: Screenshot or mock-up of the executive view alongside the **Dashboard User Guide** (defining data sources, refresh intervals, drill-down capabilities, and alert triggers).
- **Board-Level Report Structure**:
- **Executive Summary**: Non-technical summary of organizational risk reduction post-incident.
- **Strategic Risk Exposure**: Translation of technical vulnerabilities into operational and financial impact (regulatory penalties, downtime, data compromise liability).

- **Remediation & Governance Progress**: Visual comparison of risk state (Pre-remediation vs. Post-remediation).
- **Resource & Investment Justification**: Clear justification for ongoing investments in automated asset inventory, patch automation, and regular compliance audits.
- **Governance Oversight Rationale**: Explanation of how continuous metric reporting enables the board to fulfill its fiduciary duty of oversight, preventing systemic blind spots similar to those documented in the Equifax investigation.

Meaningful Governance Metrics (The Core Scorecard)

- **Financial & Value Creation**

- **EBITDA Margin:** Operating profitability relative to revenue (Target: ≥ 22%).
- **Free Cash Flow (FCF) Conversion:** Operating cash flow converted to free cash (Target: ≥ 85%).
- **Budget vs. Actual Variance:** Net variance across core operational and capital expenditures (Target: ± 3%).
- **Risk & Compliance**
- **Regulatory Compliance Rate:** Percentage of mandatory filings, licenses, and statutory audits completed on time (Target: 100%).
- **Open High-Severity Risk Items:** Count of unmitigated enterprise risks rated "High" or "Critical" past due date (Target: 0).
- **Cybersecurity & Data Privacy Posture:** Mean time to detect/resolve critical vulnerabilities and employee phishing test pass rate (Target: ≥ 95%).
- **Strategic Execution**
- **Strategic Milestone On-Time Delivery:** Percentage of annual board-approved strategic projects on schedule (Target: ≥ 85%).
- **ESG & Ethical Conduct Index:** Number of open whistleblower/ethics hotline cases and mandatory training completion rate (Target: 100% completion, 0 unresolved retaliation claims).
- **Board Effectiveness & Oversight**
- **Director Attendance & Engagement Rate:** Board and committee meeting participation percentage (Target: ≥ 90%).

  Board Evaluation & Action Item Closure: Percentage of self-assessment or governance audit recommendations closed within 180 days (Target: ≥ 80%).

Executive Governance Dashboard (Layout & Design)

An executive dashboard is a strategic management tool built for rapid scanning (the 5-second rule) rather than deep operational analysis.

----------+ | EXECUTIVE GOVERNANCE & STRATEGIC SCORECARD As of: October 2026 | +----------+ | [FINANCIAL HEALTH] | [RISK & COMPLIANCE] | [STRATEGIC EXECUTION] | | • EBITDA Margin: 24.1% (▲) | • Compliance Rate: 100% | • Milestones On-Time: 88% | | • FCF Conversion: 91% (▲) | • Critical Risks Open: 1 | • Major Projects At-Risk: 2| +----------+----------+ | EXECUTIVE SUMMARY / EXCEPTION CALLOUTS | TREND / STATUS| | 1. ERP Phase 2 migration delayed by 3 weeks; mitigation plan active | [YELLOW] | | 2. Zero open regulatory or legal breaches across all jurisdictions| [GREEN] | +----------+ | SYSTEM OF RECORD: Integrated ERP, GRC Platform, & HRIS (Monthly Refresh)

Design Rules

- **Limit to 8–12 KPIs** structured around the board's core oversight questions.
- **Use RAG (Red-Amber-Green) status indicators** tied to pre-defined numerical thresholds.
- **Anchor every metric** with an accountable owner and a clear system of record.

Board-Level Governance Report (Template)

Memorandum / Board Pack Cover

- **To:** Board of Directors
- **From:** Chief Executive Officer & Company Secretary
- **Date:** October 2026
- **Subject:** Q3 / FY26 Consolidated Governance, Risk, and Performance Report

Executive Summary

- **Holistic Performance:** The organization delivered resilient financial results this quarter, with revenue tracking 4.2% ahead of plan and EBITDA margin holding at 24.1%.
- **Key Strategic Wins:** Completion of regional market entry milestones and finalization of core vendor consolidation.
- **Critical Areas Requiring Board Focus:**

1. Resource constraint on the digital transformation rollout mitigation plan detailed in Section .

Section 1: Financial & Strategic Progress

- **Financial Performance Table:** Actual vs. Budget breakdown for Revenue, Gross Margin, EBITDA, and Free Cash Flow.
- **Strategic Roadmap Status:** High-level status of the top 5 enterprise-wide strategic bets, highlighting dependencies and bottlenecks.

Enterprise Risk & Compliance Update

- **Top 5 Enterprise Risks Matrix:** Impact vs. Likelihood mapping.
- **Compliance & Statutory Status:** Confirmation that all statutory filings, tax obligations, and sector-specific accreditations are current.
- **Incident Log:** Summary of any material cyber, legal, or health/safety incidents, root-cause analyses, and remediation steps

Governance, Ethics, and Board Operations

- **Whistleblower & Ethics Report:** Summary of hotline activity (volume, nature of claims, resolution status) managed independently via the Audit Committee.
- **Conflict of Interest & Independence Review:** Annual registry updates and director independence confirmations.
- **The So What / Board Ask:**
  - Decision Required: Approval of the revised 2027 enterprise risk appetite statement.
  - Input Requested: Guidance on expansion timelines for [Specific Region/Product Line].